COMP1608 (2023/24)	Managing IT Security and Risk	Faculty Header ID:	Contribution: 100% of course
Course Leader: **Mr Dimitrios Frangiskatos**	**Managing IT Security and Risk coursework**		**Deadline Date:** **Wednesday 13/12/2023 by 11:30pm UK Time**

This coursework will be marked anonymously
YOU MUST NOT PUT ANY INDICATION OF YOUR IDENTITY IN YOUR SUBMISSION

This coursework should take an average student who is up-to-date with tutorial work approximately 50 hours

Feedback and grades are normally made available within 15 working days of the coursework deadline

Learning Outcomes:
A. Understand and evaluate security threats and its impact on business environments.
B. Demonstrate an understanding of risk evaluation and risk control techniques
C. Formulate critically evaluated proposals to implement security
solve problems within an organisation.

UNIVERSITY OF GREENWICH

Plagiarism is presenting somebody else's work as your own. It includes: copying information directly from the Web or books without referencing the material; submitting joint coursework as an individual effort; copying another student's coursework; stealing coursework from another student and submitting it as your own work. Suspected plagiarism will be investigated and if found to have occurred will be dealt with according to the procedures set down by the University. Please see your student handbook for further details of what is / isn't plagiarism.

All material copied or amended from any source (e.g. internet, books) must be referenced correctly according to the reference style you are using.

Your work will be submitted for plagiarism checking. Any attempt to bypass our plagiarism detection systems will be treated as a severe Assessment Offence.

Coursework Submission Requirements

- **An electronic copy of your work for this coursework must be fully uploaded on the Deadline Date of** Wednesday 13/12/2023 **by 11:30pm UK Time, using the link on the coursework Moodle page for COMP1608.**
- **For this coursework you must submit a single PDF document. In general, any text in the document must not be an image (i.e. must not be scanned) and would**

normally be generated from other documents (e.g. MS Office using "Save As .. PDF"). An exception to this is hand written mathematical notation, but when scanning do ensure the file size is not excessive.

- **There are limits on the file size (see the relevant course Moodle page).**

- Make sure that any files you upload are virus-free and not protected by a password or corrupted otherwise they will be treated as null submissions.
- Your work will not be printed in colour. Please ensure that any pages with colour are acceptable when printed in Black and White.

- **You must NOT submit a paper copy of this coursework.**
- **All courseworks must be submitted as above. Under no circumstances can they be accepted by academic staff**

The University website has details of the current Coursework Regulations, including details of penalties for late submission, procedures for Extenuating Circumstances, and penalties for Assessment Offences. See http://www2.gre.ac.uk/current-students/regs

---

- **Detailed Specification**

This coursework is to be completed individually. See the scenario and tasks required for completion below.

- **Deliverables**

A report of no more than 3,000 words in a single PDF document.

- **Assessment Criteria**

The assessment criteria is based upon the marks highlighted in the sections below.

Overview

In this coursework, you will work on a scenario relating to a multinational company (MegaCorp) with a strong online presence. This is a medium-large sized company employing 1550 staff across their four branches (London, Manchester, Rome and Singapore). They have grown from a British start-up to a globally renowned end-to-end tech platform specialising in taking brands direct to consumers worldwide, through their own technology platform. Food supplements, nutrition and beauty are the domains they focus on. Key information will be supplied upon release of the coursework.

Scenario key information:

A new CSO (VP of Security) has been appointed **(that is YOU – you have this role!)**

You have to review the information provided relating to the company (e.g. their IT infrastructure, their products, their organisation etc.) and suggest IT Security improvements. You cannot interfere with the business model of the organisation (you cannot ask to change the way they conduct their business, e.g. no more online presence we will move to a paper based system!).

Hint: Think in terms of people, processes, policies, procedures. Use CIS, NIST and PCI resources to help you in your task.

The scenario

Following a few IT security incidents resulting in data loss, GDPR breaches and penalties the decision was made by MegaCorp to invest more in improving their IT security posture.

In terms of IT infrastructure, their IT estate includes approximately 50 servers (Centos 6.x and Windows 2012 standard), around 900 laptops (Windows 7 and MacOS Catalina and Mojave), 600 desktops (Windows 7 and MacOS Catalina/Mojave, Centos 6.x) and a number of core infrastructure devices (Cisco 7200 series routers, rv340 VPN devices and 6800 & SX550X-52 series switches, Fortigate firewalls FortiGate-5001A-SW-G and FortiGate-620B-G load balancers).

Virtualisation is used as well as cloud solutions (Azure and AWS).

VoIP and Cisco phones are used and the network is converged.

A part of the corporate network is flat and the use of a shared network drive for all staff is in place. This is used as a common share to store various client data, sometimes confidential (although there is a policy that states this should be happening).

There is also a separate temporary drive network that is used for temporary files (application temp storage) by all staff.

Employees work often onsite on client projects. Their devices are not always encrypted as there is no policy based encryption control, and they are allowed to install software on an as needed basis. This helps to reduce IT support involvement and workload.

Email is used widely often also used to transfer various files as needed including quotes and client information.

The joiner's onboarding process is not standardised as different teams follow their own plan. Joiners learn on the job sometimes shadowing, sometimes through trial and error.

Yearly training is not provided but members of staff are advised to find someone to shadow or to use an online resource such as YouTube to obtain the required software and related skills.

Hierarchy and job title not aways map to access rights as some staff have multiple roles not always matching their job role. Limiting their access to data will add to the workload of the IT support.

Management of the devices has become an issue as it is manual and takes too much time as the there is no MDM in place.

Vulnerability management is not implemented currently.

Security monitoring is not implemented because the systems are not configured for monitoring and there is no SOC support in place.

System patching is performed manually by users – users will receive an email and they will be asked to apply an update - there is not centralised solution in place.

Logging is very basic if not existent and account segregation is not enforced.

There is a team of developers that develop code for the organisation but they do not follow a standardised approach.

Testing and evaluation of new code sometimes takes place on production systems.

The test, development and production environments are not segregated appropriately and there have been instances that the test data made it to the production environment.

Logging is not implemented and there were instances that incident response was needed but there was no logging at all available.

Backups are not performed due to lack of HD space.

Databases do not have roll back functions enabled and there is no logging enabled due to HD space.

Account sharing is used to reduce IT workload.

The IT estate infrastructure is not monitored and a SIEM is not in place. IBM's QRadar Security is in place for the Web and database server with a retention of 30 days.

Physical security lacks and on a number of occasions unauthorised employees and guests accessed restricted areas.

There is a test environment, a development environment and a production environment. Remote working is allowed and users often work remotely. A Web based interface is used that can be accessed across the world instead of a VPN.

There is also network core equipment that has been incorporated within MegaCorp's network following a recent merger with Initech. This was added and extended MegaCorp's network. Also some Initech admin staff accounts were moved to MegaCorp's domain to allow maintenance of the newly acquired hardware. Some of the devices can be seen next but this is not to be considered a complete list (a complete list is not available – the merger happened too fast) - additional equipment might be connected and not listed.

Due to various upgrades to the network over the years a network diagram is not in place. Feel free to try and produce one if you feel it will help you with your recommendations. If you do decide to produce a network topology diagram consider the different locations, the business requirements and the security requirements etc.

Router	Juniper MX204	18.4	6
Virtual servers	Windows servers	Windows 2016	21
	Linux servers	Centos 7.7, 7.8	29
VMware Physical host/vCentre	VSphere client/vCentre	ESXi 6.5	5
VMware Orchestrator	VMware Orchestrator	7.3	4
VMware PSC	VMware PSC	6.5	4
Workstations/Laptops	Microsoft Windows	10 Pro	520
	MacOS	10.15.4	400
Storage Array	HPE Nimble Storage	5.1.4	4

This page intentionally left blank

Task 1

Based on the key information provided identify and very briefly discuss how you would improve the IT security of this organisation. You might want to focus on a few areas (up to five) that offer opportunity for improvement of the overall security posture of this company. You might want to consider discussing issues relating to Change control, Compliance, Cost, Continuity, and Coverage and mission Critical Assets (e.g. Data Security, Endpoint Security, Application Security, Network Security, Perimeter Security and the Human Layer).

[10 marks]

Task 2

Create a realistic* plan with the actions for the areas identified on Task 1 allocated to the team responsible. All assumptions must be stated.

**The plan must be realistic in terms of delivery (hint: sometimes things have to happen in a certain order, over certain timeframe, cannot happen all at once).*

Note: You have not been told what teams the organisation have - You can make assumptions about the teams they have (e.g. IT security team, Management team, Software development team), based on the information provided and common industry practices.

[10 marks]

Task 3

Identify ten security threats that are relevant to this organisation based on what it was covered in class about common threats. Perform basic risk analysis (how each of these risks might affect the business operations?). List based on criticality.

Each of these threats must be briefly explained in plain English (in general what is it, how does it usually work, what can affect within a business unit or system etc.).

a) A brief scenario (non generic) must be provided for each of these threats that is specific to this organisation.
b) A brief countermeasure recommendation must be provided for each of the scenarios provided in a) - please note this must be specific to the organisation and targeted rather than a “blanket” solution (e.g. “install better firewall” or “improve the security policy” are not acceptable answers).

Please note that a network diagram could come handy for this task

[35 marks]

Task 4

The company recently set as their immediate target to become PCI DSS compliant. Review the latest PCI DSS standard requirements (available to download from https://www.pcisecuritystandards.org/document_library/).

Based on the key information provided about this organisation, critically discuss two applicable changes that they would have the highest impact in aligning with the PCI DSS standard.

Hint: Often before any changes towards a compliance goal can be made, foundational changes might be required to allow for these changes (e.g. the creation of teams, change of processes, departments or a new or additional IT infrastructure). Please make sure you mention any such foundational changes.

[35 marks]

Task 5

Reporting

You are required to present a report with the following structure:

- Summary
- Task 1
- Task 2
- Task 3
- Task 4
- Conclusion
- References

Present your coursework as a report of no-more than 3,000 words.

This should be typed and you may use graphics and tables. We expect that you will demonstrate a systematic understanding of the discussed and analysed information security concepts.

We expect that you will use an extensive range of current and appropriate literature to support your arguments and different perspectives into the discussed and analysed information security concepts. References should be in the Harvard referencing system.

Marks are awarded for clear, coherent writing, proofread work and written English that is of an extremely high standard and observes all academic conventions in style and content. We expect to see an appropriate command of the rules of report layout, spelling, punctuation, grammar, syntax with due regard to the use if figures, diagrams and references.

[10 marks]

Grading Criteria

+70%: An excellent report (complete) answering all questions, demonstrating an excellent understanding of the concepts and with an excellent conclusion.

+60%: A good report (complete), answering all questions, showing some understanding of the concepts and with a good conclusion

+50%: A reasonable report (complete), answering all questions and with a conclusion

+40%: Report mostly complete, most questions answered and showing only a basic understanding of the concepts

+30%: Report incomplete, or demonstrates little or no understanding of the concepts poor conclusions

Marks will be reduced for a report that is not professional, for example not proofread, not formatted accordingly.

The content must be appropriately selected for the task e.g. if a screen capture or reference to a product or service is included this needs to be relevant, focused and the right size, with an appropriate explanation and clearly defined.